UNIVERSIDADE DE MOGI DAS CRUZES

SISTEMA DE INFORMAÇÃO

Luiz Antonio da Silva Correa

SISTEMA DE LOGIN SEGURO

Arquitetura modular com Spring Boot, Thymeleaf e MongoDB Atlas

Mogi das Cruzes

2026

Luiz Antonio da Silva Correa

SISTEMA DE LOGIN SEGURO

Arquitetura modular com Spring Boot, Thymeleaf e MongoDB Atlas

Relatório técnico apresentado ao curso de Sistema de Informação da Universidade de Mogi das Cruzes, como documentação da atividade prática de desenvolvimento de um sistema de autenticação e autorização.

Mogi das Cruzes

2026

RESUMO

Este relatório apresenta uma base modular de login seguro desenvolvida com Java 21, Spring Boot, Spring Security, Thymeleaf e MongoDB Atlas. O sistema permite cadastro, autenticação, encerramento de sessão e administração de usuários, com três perfis de acesso. As senhas são armazenadas como hashes BCrypt e as sessões são persistidas em documentos MongoDB. A apresentação utiliza templates e folhas de estilo independentes dos serviços de negócio. A separação facilita a futura adaptação ao tema do Projeto Final de Curso, preservando as regras centrais de segurança. A documentação descreve configuração, arquitetura, decisões técnicas e procedimentos de verificação. Os testes automatizados utilizam componentes simulados para o banco; a conexão ao cluster Atlas depende das credenciais e da rede do responsável pelo projeto.

Palavras-chave: autenticação; autorização; Spring Security; MongoDB Atlas; arquitetura modular.

SUMÁRIO

1 INTRODUÇÃO 4

2 ESTRUTURA DO SISTEMA 5

3 AUTENTICAÇÃO E AUTORIZAÇÃO 6

4 INTEGRAÇÃO COM MONGODB ATLAS 7

5 CONFIGURAÇÃO E EXECUÇÃO 8

6 INTERFACE E ADAPTAÇÃO AO PFC 9

7 VERIFICAÇÃO E LIMITAÇÕES 10

8 VERSIONAMENTO E ENTREGA 11

REFERÊNCIAS 12

1 INTRODUÇÃO

O objetivo é fornecer um sistema acadêmico independente do PFC, reutilizável em diferentes temas. O núcleo trata identidade e acesso; recursos específicos do futuro projeto devem ser acrescentados em módulos próprios.

O escopo inclui cadastro público, login, logout, validação de dados, controle administrativo e armazenamento de usuários e sessões. São definidos os perfis USER, MANAGER e ADMIN. A gestão é restrita a gerentes e administradores; a administração de usuários é exclusiva do administrador.

A aplicação adota Java 21 e Spring Boot 3.5.16. O Spring Security controla autenticação, autorização e proteção das requisições. O Thymeleaf renderiza as páginas no servidor. O Spring Data MongoDB realiza o acesso ao banco. A configuração externa permite conectar a mesma aplicação ao Atlas sem alterar o código.

A apresentação deste relatório segue critérios da NBR 14724:2024 descritos pelo manual acadêmico da PUC Goiás (2026): papel A4, margens superior e esquerda de 3 cm, inferior e direita de 2 cm, fonte Arial 12 e entrelinha 1,5 no texto. Referências e natureza do trabalho usam espaço simples. A instituição pode exigir elementos adicionais na entrega final.

2 ESTRUTURA DO SISTEMA

O pacote br.edu.login.user reúne Account, Role, Registration, AccountRepository e AccountService. Account representa o usuário; Registration delimita os dados aceitos no cadastro; o repositório consulta documentos e o serviço concentra normalização, hash e alterações administrativas.

O pacote security contém SecurityConfig, AccountStatusFilter e AdminBootstrap. As regras HTTP são centralizadas; o filtro reconsulta o usuário autenticado para identificar exclusão, bloqueio ou mudança de perfil. O bootstrap cria a primeira conta administrativa com credenciais externas.

O pacote session integra Spring Session Core ao MongoDB por meio de SessionRepository<MapSession>. SessionConfig habilita o filtro de sessão e configura o cookie. MongoSessionRepository implementa criação, leitura, gravação e remoção de documentos.

O pacote web contém os controladores e ThemeAdvice. Os controladores recebem formulários, aplicam validação e selecionam páginas; ThemeAdvice limita os identificadores de tema. Os arquivos de apresentação ficam em resources/templates e resources/static/css.

O fluxo principal é: navegador, cadeia de filtros, controlador, serviço, repositório e MongoDB. A resposta passa pelo template Thymeleaf. Recursos de domínio futuros devem seguir o mesmo percurso, sem transferir regras de autorização para o CSS ou para o navegador.

3 AUTENTICAÇÃO E AUTORIZAÇÃO

No cadastro, o servidor valida nome, e-mail e senha. O e-mail é normalizado com remoção de espaços externos e conversão para minúsculas. Um índice único impede duplicidade inclusive diante de requisições concorrentes. O cliente não escolhe o próprio perfil; todo cadastro público começa como USER.

A senha exige 12 a 64 caracteres, com maiúscula, minúscula e número. Há validação adicional de até 72 bytes UTF-8 devido ao limite do BCrypt. O PasswordEncoder usa BCrypt com custo 12 e salt gerado pelo algoritmo. O texto original não é armazenado. Hash é uma operação de mão única, e não criptografia reversível (Spring, s.d.).

O Spring Security consulta o usuário pelo e-mail e verifica o hash. A mensagem de falha é genérica. Após autenticação, o identificador de sessão é renovado para reduzir risco de fixação. O logout é enviado por POST e remove a sessão e o cookie.

As rotas /dashboard, /manager e /admin/users exigem, respectivamente, autenticação, MANAGER ou ADMIN, e ADMIN. A administração permite consultar, editar e excluir usuários. O administrador não altera nem exclui a própria conta pela interface, preservando seu acesso de recuperação.

A proteção CSRF permanece ativa e os formulários Thymeleaf recebem o token. O cookie utiliza HttpOnly e SameSite=Lax. Em HTTPS, COOKIE_SECURE deve ser true. A política CSP restringe fontes de conteúdo à própria origem. O filtro de status invalida sessões com permissões antigas na próxima requisição.

4 INTEGRAÇÃO COM MONGODB ATLAS

O Atlas hospeda as coleções users e sessions. Cada usuário possui identificador, nome, e-mail, passwordHash, role e enabled. Não há campo de senha em texto puro. Em users, o e-mail possui índice único.

Cada sessão registra identificador, criação, último acesso, duração, expiresAt e atributos. A duração padrão é de 30 minutos sem atividade. O índice TTL em expiresAt permite limpeza automática; a aplicação também verifica a expiração ao ler o documento, pois a limpeza TTL não ocorre instantaneamente.

A integração usa Spring Session Core e um adaptador próprio, evitando depender de uma extensão MongoDB antiga. Os atributos internos são serializados em formato binário, incluindo o contexto de segurança. A escrita no banco deve ficar restrita à aplicação: a desserialização Java exige uma origem confiável. Uma mudança incompatível nas classes exige invalidar sessões antigas.

A URI é fornecida exclusivamente pela variável MONGODB_URI. O protocolo mongodb+srv utiliza descoberta DNS e TLS; o modelo de conexão mantém tls=true (MongoDB, s.d.). Usuário e senha devem ser percent-encoded quando contiverem caracteres reservados. O arquivo público de exemplo não contém uma credencial real.

No Atlas, crie um usuário de banco com readWrite apenas no banco login_seguro e autorize somente os IPs necessários em Network Access. O usuário de banco é diferente dos usuários da aplicação. Certificados devem ser validados; não use opções que desativem TLS ou permitam certificados inválidos.

5 CONFIGURAÇÃO E EXECUÇÃO

Para execução local com Java, instale JDK 21 e Maven 3.9 ou superior. Configure MONGODB_URI no ambiente com a conexão do Atlas. Execute mvn verify para compilar e testar; execute mvn spring-boot:run para iniciar. A aplicação atende em http://localhost:8080.

Para Docker, inicie o Docker Desktop com containers Linux, copie .env.example para .env e preencha os valores. Execute docker compose up --build. O arquivo compose.yml carrega .env e publica a porta somente na interface local. O Dockerfile executa os testes no build e roda a aplicação como usuário sem privilégios.

Na primeira execução, informe BOOTSTRAP_ADMIN_EMAIL e BOOTSTRAP_ADMIN_PASSWORD com valores exclusivos e fortes. O bootstrap só cria a conta se o e-mail não estiver cadastrado; não promove automaticamente uma conta comum existente. Remova as variáveis após a criação. Não há conta com senha padrão.

O Spring Boot não carrega .env automaticamente na execução Maven. Nesse modo, configure as variáveis do processo conforme o README. A ausência de MONGODB_URI impede iniciar o sistema com configuração incompleta.

Para HTTPS, configure certificado no servidor ou proxy e defina COOKIE_SECURE=true. Essa variável apenas controla o envio do cookie; não fornece um certificado. Mantenha false apenas no desenvolvimento HTTP local. Falhas de conexão devem ser investigadas pela URI, resolução DNS, allowlist de rede e permissões do usuário de banco.

6 INTERFACE E ADAPTAÇÃO AO PFC

Os templates contêm a estrutura das páginas; as folhas CSS definem apresentação. Há páginas para login, cadastro, painel, gestão, administração e erro. O Thymeleaf escapa conteúdo de usuários, e os links visíveis acompanham as permissões fornecidas pelo Spring Security.

A base visual é definida em static/css/base.css. Os temas default e forest alteram variáveis de cor em arquivos próprios. APP_THEME escolhe a paleta e ThemeAdvice aceita apenas nomes previamente autorizados. Essa lista impede que o valor de configuração seja usado como caminho arbitrário.

Para um novo tema, crie um arquivo CSS em static/css/themes, registre seu nome na lista permitida e altere APP_THEME. Para uma mudança estrutural, edite os templates. As regras de senha, sessão e autorização continuam nos serviços e filtros, sem depender do novo design.

Para adaptar ao PFC, crie pacotes de domínio com entidades, serviços e repositórios próprios. Adicione páginas e controladores e registre explicitamente as permissões das novas rotas em SecurityConfig. A página de gestão é um ponto de extensão; não representa um módulo de negócio já implementado.

Caso o projeto exija novos perfis, revise Role, regras HTTP, testes de acesso e links do menu. Preserve a atribuição de USER no cadastro público. Se alterar a forma de persistência, mantenha o contrato de sessão e os índices de expiração para evitar sessões indefinidas.

7 VERIFICAÇÃO E LIMITAÇÕES

Os testes automatizados verificam normalização de e-mail, hash BCrypt, privilégio inicial e rejeição de senhas acima do limite em bytes. Os testes HTTP verificam redirecionamento anônimo, negação por perfil, acesso autorizado, token CSRF, validação, logout e revogação por bloqueio ou mudança de perfil.

Os testes do repositório de sessões verificam round-trip de atributos, rotação de identificador e rejeição de sessão expirada. MongoTemplate é simulado: esses testes não comprovam conectividade ao Atlas, comportamento real de seus índices ou disponibilidade de rede. O fluxo de CI executa mvn verify sem credenciais.

A validação manual deve cadastrar um usuário, rejeitar duplicidade, testar credenciais incorretas e corretas, observar o hash em users e a sessão em sessions e encerrar o acesso por logout. Com a conta administrativa, deve promover um usuário a MANAGER, bloquear uma conta conectada e verificar revogação na requisição seguinte.

A integração real ao Atlas exige a URI privada e a autorização de rede do responsável. A entrega não inclui uma alegação de teste no cluster sem essas condições. O roteiro manual do README deve ser executado antes da demonstração acadêmica.

A base não implementa MFA, recuperação de senha, verificação de e-mail nem limitação de tentativas de login. Antes de exposição pública, acrescente rate limiting no proxy e os controles adequados ao contexto. Sessões simultâneas são permitidas. Listagens administrativas ainda não usam paginação.

8 VERSIONAMENTO E ENTREGA

O repositório da atividade é separado do PFC: github.com/Luizcorrea00/Atividade-Pratica-login. Gitflow organiza main para entregas, develop para integração, feature/* para desenvolvimento, release/* para preparação e hotfix/* para correções urgentes.

Uma funcionalidade parte de develop e retorna por merge sem fast-forward. Uma release parte de develop, recebe verificação e documentação, é integrada em main e develop e recebe uma tag de versão. Hotfixes partem de main e retornam às duas branches. O README contém comandos para continuar esse fluxo.

O código público deve incluir fontes, pom.xml, configuração sem segredos, templates, CSS, Dockerfile, workflow de CI, testes, README e este relatório. .env, arquivos de log, ferramentas locais e artefatos temporários ficam fora do versionamento. O responsável deve conferir a visibilidade pública no GitHub e a execução do workflow.

As principais decisões são: BCrypt para hash adaptativo, privilégio mínimo no cadastro, regras centralizadas no servidor, validação de dados, sessão persistente com expiração, configuração externa de credenciais e temas com lista permitida. Essas decisões preservam uma base genérica para evolução futura.

A aplicação e a documentação formam uma base de trabalho: após conectar o Atlas, validar os cenários reais e publicar as branches, o estudante deve revisar o comportamento e explicar as escolhas técnicas na apresentação da atividade.

REFERÊNCIAS

MONGODB. Connection string options. [S. l.], s.d. Disponível em: https://www.mongodb.com/docs/manual/connection-string-options/. Acesso em: 7 out. 2026.

PONTIFÍCIA UNIVERSIDADE CATÓLICA DE GOIÁS. Normalização de trabalhos acadêmicos. Goiânia, 2026. Disponível em: https://www.pucgoias.edu.br/mestrado-e-doutorado/wp-content/uploads/sites/27/2026/03/Normalizado2026-Final.pdf. Acesso em: 7 out. 2026.

SPRING. Password storage. [S. l.], s.d. Disponível em: https://docs.spring.io/spring-security/reference/servlet/authentication/passwords/password-encoder.html. Acesso em: 7 out. 2026.

SPRING. Spring Session reference. [S. l.], s.d. Disponível em: https://docs.spring.io/spring-session/reference/. Acesso em: 7 out. 2026.

SPRING. System requirements: Spring Boot 3.5. [S. l.], s.d. Disponível em: https://docs.spring.io/spring-boot/3.5/system-requirements.html. Acesso em: 7 out. 2026.